

AdatTracker Pro

Hardened Technical Architecture, Multi-Tenant Security & Production Operations Reference

Repository: github.com/12thpassengineer/HabitTracker **Version:** v2.5 Enterprise Hardened **License:** MIT

Date: August 2026

1. Philosophy & Brand Identity

To eliminate third-party trademark liability, preserve complete code ownership, and build a high-performance personal habit operating system, the project was officially named **AdatTracker Pro**.

"You do not rise to the level of your goals. You fall to the level of your systems (adats)."

"Adat" (ادات / आदत) translates directly to *habit, ritual, or discipline* across South Asian and Middle Eastern cultures.

2. Feature Architecture

- **Monthly Habit Matrix:** 31-day widescreen grid with auto-scroll to today's date, streak counters (🔥), and completion rates (%).
- **Drag & Drop Priority Reordering:** Minimalist ☰ drag handles for real-time habit priority organization.
- **Proportional Consistency Scoring:**
$$\text{Daily Score} = \frac{\text{Completed Habits}}{\text{Total Active Habits}}$$
(e.g. 4/5 habits = +0.80 pts).
- **OLED Sticky Notes Pad:** 6 color palettes (Yellow, Green, Purple, Cyan, Pink, Slate) with Pin (📌), Copy (📄), and search.
- **Passwordless Email OTP:** 6-digit cryptographic verification with 10-minute expiry, purpose segregation, atomic consumption, and attempt lockout.
- **2-Second Contextual Hover Guides:** Automatic dwell helper modals on all statistics and controls.
- **Offline Local Mode:** Automatic fallback to browser localStorage if server connection is lost.

3. Security Architecture & Threat Model

 Security Guarantees

Zero tokens in localStorage • HttpOnly SameSite=Lax cookie sessions • Mandatory CSRF double-submit protection on mutate & logout • Serialized BEGIN IMMEDIATE rate limiting • Zero OTP log leakage • Non-root execution (UID 1001) • SQLite WAL mode • Strict user isolation.

Security Layer	Mechanism	Implementation Detail
Authentication	Unified 1-Step Email OTP	Single email input for signin/signup. HMAC-SHA256 hashed with server SECRET_KEY salt, atomic single-use conditional UPDATE, 10-min expiry, zero OTP log leakage, onboarding display name and optional phone setup.
Session Management	HttpOnly Cookies	256-bit URL-safe session token, 30-day expiry, SameSite=Lax, Secure flag auto-enabled in production.
CSRF Defense	Double-Submit Header	All state-mutating requests (<code>POST /api/data</code>), profile updates (<code>POST /api/auth/profile</code>), and logout (<code>POST /api/auth/logout</code>) validate <code>X-CSRF-Token</code> against active session.
User Isolation	Server-Enforced User ID	Server derives identity solely from session cookie. Client-supplied <code>user_id</code> query params or payload IDs are strictly ignored.
Rate Limiting	Serialized DB-Backed Limiter	IP and Email rate limiting (Cloudflare <code>CF-Connecting-IP</code> aware), <code>BEGIN IMMEDIATE</code> SQLite serialization, attempt lockout after 5 incorrect guesses.
Ingress Security	Cloudflare Tunnel + BIND_HOST	In production, container binds to <code>127.0.0.1:8000</code> . Port 8000 is never exposed publicly to the internet.
Payload Security	Size Capping & CSP	Requests > 512 KB receive 413 Payload Too Large. Strict CSP headers block unauthorized scripts.

4. Multi-Backend Email Dispatcher

1. **Resend API Backend:** Modern transactional delivery supporting verified custom domains (e.g. `noreply@darsan.co.in`) with zero fallback OTP printing to logs.

2. **Standard SMTP Backend:** Universal SMTP integration for Gmail (App Passwords), Amazon SES, Mailgun, Brevo (STARTTLS / SSL).
3. **Console Simulator:** Development mode printing prominent ASCII verification boxes directly into container logs.

5. Complete Database Schema (SQLite WAL)

```
-- High Concurrency WAL Configuration
PRAGMA journal_mode = WAL;
PRAGMA foreign_keys = ON;
PRAGMA busy_timeout = 5000;
PRAGMA synchronous = NORMAL;

-- 1. Users Table
CREATE TABLE IF NOT EXISTS users (
    id TEXT PRIMARY KEY,
    username TEXT UNIQUE NOT NULL COLLATE NOCASE,
    email TEXT UNIQUE NOT NULL COLLATE NOCASE,
    phone TEXT,
    role TEXT NOT NULL DEFAULT 'user',
    is_verified INTEGER NOT NULL DEFAULT 1,
    created_at TEXT NOT NULL,
    last_login TEXT NOT NULL
);

-- 2. Email OTPs Table
CREATE TABLE IF NOT EXISTS email_otp (
    id INTEGER PRIMARY KEY AUTOINCREMENT,
    email TEXT NOT NULL COLLATE NOCASE,
    otp_hash TEXT NOT NULL,
    purpose TEXT NOT NULL,
    attempts INTEGER NOT NULL DEFAULT 0,
    expires_at TEXT NOT NULL,
    used INTEGER NOT NULL DEFAULT 0,
    ip_address TEXT,
    created_at TEXT NOT NULL
);

-- 3. Server-Side Sessions Table
CREATE TABLE IF NOT EXISTS sessions (
    id TEXT PRIMARY KEY,
    user_id TEXT NOT NULL,
    csrf_token TEXT NOT NULL,
    expires_at TEXT NOT NULL,
    ip_address TEXT,
    user_agent TEXT,
    created_at TEXT NOT NULL,
    FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE CASCADE
```

```

);

-- 4. Rate Limits Table
CREATE TABLE IF NOT EXISTS rate_limits (
    key TEXT PRIMARY KEY,
    attempts INTEGER NOT NULL DEFAULT 0,
    window_start TEXT NOT NULL,
    blocked_until TEXT
);

-- 5. User Data Table (Strictly isolated by user_id)
CREATE TABLE IF NOT EXISTS user_data (
    user_id TEXT PRIMARY KEY,
    data_json TEXT NOT NULL,
    updated_at TEXT NOT NULL,
    version INTEGER DEFAULT 1,
    FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE CASCADE
);

-- 6. Subscriptions Table (₹21/mo Razorpay UPI AutoPay)
CREATE TABLE IF NOT EXISTS subscriptions (
    id TEXT PRIMARY KEY,
    user_id TEXT NOT NULL,
    razorpay_subscription_id TEXT UNIQUE,
    plan TEXT NOT NULL DEFAULT 'hosted_monthly',
    status TEXT NOT NULL DEFAULT 'inactive', -- active, pending, halted, cancelled, expired
    current_period_start TEXT,
    current_period_end TEXT,
    created_at TEXT NOT NULL,
    updated_at TEXT NOT NULL,
    cancelled_at TEXT,
    FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE CASCADE
);

-- 7. Webhook Events Table (Idempotency Engine)
CREATE TABLE IF NOT EXISTS webhook_events (
    event_id TEXT PRIMARY KEY,
    event_type TEXT NOT NULL,
    processed_at TEXT NOT NULL
);

```

6. Razorpay Subscriptions & UPI AutoPay (₹21/month)

Dual-Mode Architecture

Self-Hosted (`BILLING_ENABLED=false`): Free forever, zero payment gateway prompts or dependencies.

Hosted Cloud (`BILLING_ENABLED=true`): Seamless ₹21/month recurring subscription with UPI AutoPay (PhonePe,

GPay, Paytm, BHIM). HMCA-SHA256 verified webhooks, automatic retries with pending grace periods, and non-destructive data retention.

7. Complete REST API Specification

Method	Endpoint	Authentication	Description
GET	/	Public	Serves the single-page application frontend
GET	/health	Public	Healthcheck returning <code>{"status": "ok"}</code> with zero metadata leakage
POST	/api/auth/send-otp	Public (Rate Limited)	Generates & sends single-use 6-digit cryptographic OTP
POST	/api/auth/verify-otp	Public (Rate Limited)	Verifies OTP, resolves user, sets <code>at_session</code> cookie
GET	/api/auth/me	Session Cookie	Returns profile, CSRF token, and billing metadata
POST	/api/auth/profile	Session Cookie + CSRF	Updates display name & optional phone number
POST	/api/auth/logout	Session Cookie + CSRF	Validates CSRF, invalidates session, deletes cookie
GET	/api/subscription	Session Cookie	Returns current user's subscription status & plan info
POST	/api/billing/create-subscription	Session Cookie + CSRF	Initializes ₹21/mo recurring subscription on Razorpay
POST	/api/billing/cancel-subscription	Session Cookie + CSRF	Cancels active AutoPay mandate on Razorpay
POST	/api/billing/webhook	Webhook Signature	Authoritative Razorpay webhook ingress (HMAC-SHA256 verified)

Method	Endpoint	Authentication	Description
GET	/api/data	Active Subscription	Fetches isolated habits, tasks, and notes payload (402 if inactive)
POST	/api/data	Active Subscription + CSRF	Debounced save of user data JSON (Max 512 KB, 402 if inactive)

8. Portainer Stack Specification (Production-Tested)

```
version: "3.8"

services:
  adattracker:
    image: python:3.11-slim
    container_name: adattracker-pro
    restart: unless-stopped
    ports:
      - "8000:8000"
    environment:
      APP_ENV: production
      HOST: 127.0.0.1
      PORT: 8000
      DATA_DIR: /app/data
      BILLING_ENABLED: "true"
      RAZORPAY_KEY_ID: ${RAZORPAY_KEY_ID}
      RAZORPAY_KEY_SECRET: ${RAZORPAY_KEY_SECRET}
      RAZORPAY_WEBHOOK_SECRET: ${RAZORPAY_WEBHOOK_SECRET}
      RAZORPAY_PLAN_ID: ${RAZORPAY_PLAN_ID}
      EMAIL_BACKEND: resend
      RESEND_API_KEY: ${RESEND_API_KEY}
      FROM_EMAIL: noreply@darsan.co.in
      FROM_NAME: AdatTracker Pro
      SECRET_KEY: ${SECRET_KEY}
    volumes:
      - adattracker_data:/app/data
    command:
      - /bin/sh
      - -c
      - |
        set -eu
        apt-get update -qq && apt-get install -y -qq git curl
        rm -rf /app/repo
        mkdir -p /app/data
        git clone --depth 1 https://github.com/12thpassengineer/HabitTracker.git /app/repo
        cd /app/repo
        pip install --no-cache-dir -r requirements.txt --quiet
```

```
exec python server.py
healthcheck:
  test: ["CMD", "python", "-c", "import urllib.request; urllib.request.urlopen('http://127.0.0.1:
interval: 30s
timeout: 5s
start_period: 30s
retries: 3

volumes:
  adattracker_data:
    driver: local
```

9. Cloudflare Tunnel Deployment Blueprint (Oracle Cloud)

```
# /etc/cloudflared/config.yml
tunnel: <TUNNEL_UUID>
credentials-file: /etc/cloudflared/<TUNNEL_UUID>.json

ingress:
  - hostname: habits.darsan.co.in
    service: http://localhost:8000
  - service: http_status:404
```

10. Automated Security & Billing Test Suites

```
# Run Core Security & Data Isolation Tests (17/17 tests)
python tests/test_security.py

# Run Razorpay Subscriptions & UPI AutoPay Lifecycle Tests (16/16 tests)
python tests/test_billing.py
```